



Fig. 2: Security testing

customers WHERE custNAME="" + request.getParameter("name") + "";

Scenario #2: Vulnerable query in Hibernate Query Language

```
Query HQLQuery = session.
createQuery("FROM customer
WHERE custNAME="" + request.
getParameter("name") + "");
```

In both scenarios, the attacker modifies the 'name' parameter value to send: ' or '1'='1.

<http://testexample.com/app/customerView?name=' or '1'='1>

This changes the meaning of queries to return all the records from the customer table. More dangerous attacks could invoke stored procedures or modify data.

Broken authentication and session management. It includes all form of handling user authentication and management of active sessions. A site may be vulnerable if:

1. User authentication credentials aren't protected when stored using hashing or encryption
2. Session IDs are exposed in the URL
3. Session IDs aren't rotated after successful login and passwords
4. Session IDs and other credentials are sent over unencrypted connections

To impersonate a user, an attacker uses leaks or flaws, such as exposed session IDs, accounts and passwords, in the authentication or session management. When attack is successful, an

attacker may have the same privilege level of the system as that of a legal authorised user. An attack scenario is given below as an example:

Scenario #1: Ticket reservations application supports URL rewriting:

<http://Testexample.com/sale/ite msjsessionid=2P0OC2JSNDLP SKHCJ UN2JV?destn=Delhi>

An authenticated user of the site mails the above link to his friends without knowing that he is also giving away his session ID. When his friends use this link, they will use his session and credit card information.

Cross site scripting. It is a web vulnerability in which malicious script is injected into the system in the form of input. Three major types of cross-site scripting exist. The first one is Reflected XSS, in which attacker injects browser-executable code within a single HTTP response. It is non-persistent. Second type is Stored XSS, which occurs when some malicious user-submitted data is stored in a database to be used in the creation of pages that will be served to other users later. Thus, visitors of the web page fall victim to this attack. The third, Local XSS, targets vulnerabilities that occur in the source code itself. It is a type of XSS vulnerability which does not originate from the local software of the user.

Fuzzing testing. Fuzzing is a type of negative testing that involves injecting unexpected, random data as an input to

the application, to test the behaviour of application under random data. Fuzzing is used to find security loopholes in operating system, software, web application and coding errors.

Cross-site request forgery. Also known as a one-click attack or session riding, and abbreviated as CSRF or XSRF, it is a type of malicious exploit of a website whereby unauthorised commands are transmitted from a user that the website trusts.

Insecure direct object reference. It occurs when an application exposes an internal implementation object to the user. Some examples of internal implementation objects are database records, URLs or files. An attacker can modify the internal implementation object in an attempt to abuse the access controls on this object.

Comparison of security testing tools

In order to compare the representative testing tools, we consider the sample of web application Jammu and Kashmir Employment System. The system aims to immediately provide the facility for citizens to submit online form for the services identified by the state of Jammu & Kashmir. Subsequently, the citizen must be able to check the status of his/her application online. These submissions and status tracking can be done through the Common Service Centres (CSCs) or through the J&K State Portal directly.

Jammu and Kashmir Employment System will help the government of Jammu & Kashmir in creating an integrated information infrastructure that will expand, integrate and enhance the utility and reach of the services provided by the government by utilising the network of the CSCs. The state-portal is envisioned as an informative, interactive, integrated and trusted service delivery channel for the government to citizens (G2C) and government to business (G2B) services of the state and the government's constituent departments. The SSDG acts as hub (standards-based messaging switch) for all the interactions and seamless interoperability